

Laporan Keamanan Informasi

Proposal Teknis Proyek

Sistem TUMBUH

IPB Career & Internship Tracker

Kelompok 9

Ghiffari Bravia Hisham - G6401231050

Adam Naufal - G6401231082

Rafif Muhammad Farras - G6401231102

Mata Kuliah

KOM1315 Keamanan Informasi

Sistem

TUMBUH - Career & Internship Tracker

Proposal Teknis Proyek

1. Identitas Proyek

- Mata kuliah: KOM1315 Keamanan Informasi
- Nama sistem: TUMBUH
- Bentuk sistem: aplikasi web Career & Internship Tracker untuk mahasiswa IPB, HR perusahaan, dan admin platform
- Fokus pengembangan keamanan: Authentication, Authorization, Accounting (AAA), password hashing, enkripsi data sensitif, dan digital signature
- Repositori: KOM1315_SmtGenap26_Kelompok9_TUMBUH

2. Latar Belakang

TUMBUH adalah rancangan sistem informasi untuk membantu mahasiswa IPB menemukan lowongan kerja, magang, dan program pengembangan karier. Sistem ini juga membantu HR perusahaan mengelola profil perusahaan, mempublikasikan lowongan, dan meninjau lamaran mahasiswa. Admin platform berperan mengawasi aktivitas sistem, mengelola data pengguna, dan menjaga kualitas data pada platform.

Sebagai sistem yang menangani data pribadi, data akademik, informasi perusahaan, dan proses lamaran, TUMBUH membutuhkan kontrol keamanan yang jelas. Pada tahap awal analisis ini, TUMBUH diasumsikan sebagai sistem yang sudah memiliki fungsi bisnis utama, tetapi belum memiliki sistem keamanan yang matang seperti JWT authentication, role-based authorization, accounting atau audit logging, password hashing yang kuat, enkripsi data sensitif, dan digital signature.

Kondisi tersebut menimbulkan risiko keamanan karena pengguna dengan peran berbeda dapat berinteraksi dengan data yang sensitif. Tanpa kontrol keamanan yang baik, sistem rentan terhadap penyalahgunaan akun, akses tidak sah, manipulasi data lamaran, pencurian informasi pribadi, dan penyangkalan aktivitas oleh pengguna.

3. Deskripsi Sistem TUMBUH

TUMBUH memiliki tiga aktor utama:

Aktor	Deskripsi	Kebutuhan utama
Mahasiswa	Pengguna yang mencari lowongan, membuat profil, menyimpan lowongan, dan mengirim lamaran	Akses aman ke profil pribadi, CV, lamaran, dan status seleksi
HR perusahaan	Pengguna dari perusahaan yang membuat lowongan dan memproses pelamar	Akses aman ke data perusahaan, lowongan, dan data pelamar
Admin platform	Pengelola sistem yang mengawasi pengguna, perusahaan, konten, dan aktivitas sistem	Kontrol administratif, monitoring, dan audit aktivitas

Alur utama sistem:

1. Mahasiswa membuat akun dan mengisi profil.
2. HR membuat atau memperbarui profil perusahaan.
3. HR mempublikasikan lowongan kerja atau magang.
4. Mahasiswa melihat lowongan dan mengirim lamaran.
5. HR meninjau lamaran dan memperbarui status seleksi.
6. Admin memantau aktivitas sistem dan menangani data yang bermasalah.

4. System Overview

Setelah dianalisis dilakukan, ditemukan hal berikut pada sistem:

- Sistem belum memiliki authentication yang kuat.
- Sistem belum menggunakan JWT atau mekanisme session management yang aman.
- Sistem belum memiliki role-based access control yang konsisten.
- Sistem belum mencatat aktivitas penting pengguna dalam audit log.
- Password belum dipastikan tersimpan menggunakan hashing dan salting yang kuat.
- Data sensitif belum memiliki strategi enkripsi.
- Perubahan data penting belum dilindungi dengan digital signature.
- Belum ada pengujian keamanan khusus untuk memastikan kontrol AAA berjalan.

5. Identifikasi Aset Data

Aset	Contoh data	Tingkat sensitivitas	Risiko utama
Akun pengguna	email, password, role	Tinggi	pencurian akun, impersonation
Profil mahasiswa	nama, NIM, jurusan, GPA, bio, kontak	Tinggi	kebocoran data pribadi dan akademik

CV atau resume	riwayat pendidikan, pengalaman, kontak	Tinggi	penyalahgunaan data pribadi
Data perusahaan	nama perusahaan, industri, alamat, kontak HR	Sedang-Tinggi	manipulasi identitas perusahaan
Lowongan	judul, deskripsi, persyaratan, deadline	Sedang	perubahan tidak sah atau lowongan palsu
Lamaran	mahasiswa, lowongan, status seleksi, cover letter	Tinggi	manipulasi status dan pelanggaran privasi
Log aktivitas	login, perubahan data, akses admin	Tinggi	kehilangan bukti aktivitas dan investigasi sulit
Kunci kriptografi	secret key, private key, token signing key	Sangat tinggi	kompromi seluruh kontrol keamanan

6. Vulnerability Assessment Awal

Area	Potensi celah	Dampak
Authentication	Login lemah atau tidak ada validasi kredensial yang kuat	Penyerang dapat masuk sebagai pengguna lain
Password storage	Password disimpan plaintext atau hashing lemah	Password bocor jika database terekspos
Authorization	Endpoint tidak membedakan mahasiswa, HR, dan admin	Pengguna dapat mengakses data yang bukan haknya
Session/token	Token tidak aman, tidak punya masa berlaku, atau mudah dipalsukan	Sesi pengguna dapat diambil alih
Accounting	Tidak ada audit log aktivitas penting	Aktivitas berbahaya sulit dilacak
Data protection	Data pribadi dan CV tidak dienkripsi	Kebocoran data berdampak langsung pada pengguna
Integrity	Status lamaran dapat diubah tanpa bukti kuat	Data seleksi dapat dimanipulasi
Non-repudiation	Tidak ada digital signature untuk aksi penting	Pengguna dapat menyangkal perubahan data
Configuration	Secret key atau kredensial dikomit ke repo	Seluruh sistem dapat dikompromikan

7. Analisis Kebutuhan Keamanan

7.1 Authentication

Sistem harus memastikan bahwa pengguna yang masuk benar-benar memiliki identitas yang sah. Kebutuhan keamanan:

- Login menggunakan email dan password.
- Password disimpan menggunakan hashing dan salting yang kuat.
- Sistem menggunakan access token dengan masa berlaku terbatas.
- Refresh token atau mekanisme pembaruan sesi perlu dikontrol.
- Token tidak boleh berisi informasi rahasia.
- Endpoint sensitif hanya dapat diakses oleh pengguna yang sudah terautentikasi.

7.2 Authorization

Sistem harus memastikan pengguna hanya dapat mengakses fitur sesuai perannya. Kebutuhan keamanan:

- Role minimal: `student`, `hr`, dan `admin`.
- Mahasiswa hanya dapat mengakses profil dan lamaran miliknya sendiri.
- HR hanya dapat mengelola perusahaan, lowongan, dan pelamar yang terkait dengan perusahaannya.
- Admin dapat mengelola data platform sesuai kebutuhan pengawasan.
- Setiap endpoint penting harus memiliki pengecekan role dan ownership.

7.3 Accounting

Sistem harus mencatat aktivitas penting untuk audit dan investigasi. Kebutuhan keamanan:

- Mencatat login berhasil dan gagal.
- Mencatat pembuatan, perubahan, dan penghapusan data penting.
- Mencatat perubahan status lamaran.
- Mencatat aktivitas admin.
- Log harus memuat waktu, pengguna, role, aksi, resource, status berhasil/gagal, dan alamat IP jika tersedia.
- Log tidak boleh menyimpan password, token, private key, atau data rahasia lain.

7.4 Enkripsi Data Sensitif

Data yang memiliki risiko tinggi perlu dilindungi. Kebutuhan keamanan:

- Mengidentifikasi kolom atau file yang perlu dienkripsi.
- Menyimpan kunci enkripsi di konfigurasi aman, bukan di source code.
- Melindungi CV, dokumen mahasiswa, atau data sensitif lain sesuai kebutuhan.
- Memastikan proses enkripsi dan dekripsi terintegrasi dengan workflow utama.

7.5 Digital Signature

Digital signature digunakan untuk menjaga integritas dan non-repudiation pada aksi penting. Kebutuhan keamanan:

- Menandatangani transaksi atau perubahan data penting.
- Memverifikasi tanda tangan sebelum menerima data penting.
- Menyimpan private key secara aman dan tidak memasukkannya ke repositori.
- Mencatat hasil verifikasi dalam audit log jika relevan.

8. Ruang Lingkup Implementasi Keamanan

Ruang lingkup pengembangan pada tugas ini:

1. Merancang dan mengimplementasikan AAA security pada TUMBUH.
2. Menambahkan password hashing dan salting.
3. Menambahkan role-based access control.
4. Menambahkan audit logging untuk aktivitas penting.
5. Menambahkan enkripsi untuk data sensitif yang dipilih.
6. Menambahkan digital signature untuk aksi penting yang membutuhkan non-repudiation.
7. Menyusun log pengujian untuk membuktikan kontrol keamanan berjalan.

9. Existing System Analysis

Sistem TUMBUH pada kondisi awal dirancang untuk menyelesaikan masalah akses informasi karier dan magang bagi mahasiswa IPB. Sistem ini mempertemukan mahasiswa, HR perusahaan, dan admin platform dalam satu aplikasi web. Dari sisi fungsional, sistem ini mendukung proses pencarian lowongan, pengiriman lamaran, pengelolaan perusahaan, dan pemantauan data oleh admin.

Namun, sistem yang menangani proses karier dan data pribadi tidak cukup hanya memenuhi kebutuhan fungsional. Data seperti profil mahasiswa, CV, status lamaran, dan akun pengguna memiliki nilai sensitif. Jika tidak diamankan, sistem dapat menjadi target pencurian identitas, pengubahan data lamaran, akses tidak sah oleh pengguna internal, maupun penyalahgunaan hak admin.

Kelemahan utama pada sistem yang ada adalah belum adanya pemisahan kontrol keamanan yang jelas antara Authentication, Authorization, dan Accounting. Tanpa authentication yang kuat, sistem tidak dapat menjamin identitas pengguna. Tanpa authorization, pengguna dapat mengakses atau mengubah data di luar haknya. Tanpa accounting, sistem tidak memiliki bukti aktivitas untuk investigasi ketika terjadi insiden.

Oleh karena itu, pada proyek ini diusulkan integrasi AAA security sebagai fondasi keamanan TUMBUH. Integrasi tersebut dilengkapi dengan password hashing, enkripsi data sensitif, digital signature, dan pengujian keamanan untuk memastikan kontrol yang dirancang benar-benar bekerja pada workflow utama sistem.

10. Kesimpulan

Proposal teknis ini menetapkan TUMBUH sebagai sistem final yang akan diamankan pada tugas PBL Keamanan Informasi. Fokus utama proyek adalah mengubah TUMBUH dari sistem fungsional yang belum aman menjadi sistem dengan kontrol keamanan berbasis AAA, perlindungan data sensitif, dan bukti audit aktivitas pengguna.